PROJET MONTFRANC SMART CITY

Etude Des Cas

EBIOS-RM, NIST,CIS Smart Water Management







2025-2026

Tuteur Enseignant :
W.GOUDALO

Travaille réalisé par
Daouda TOGOLA

Table des matières

1. INTRODUCTION 3
2. PÉRIMÈTRE ET OBJECTIFS 3
2.1 Définition du Périmètre 3
2.2 Actifs Essentiels 4
2.3 Objectifs de Sécurité (SSI) 4
2.4 Cadre Réglementaire et Normes 4
3. ANALYSE DE RISQUES (EBIOS RM) 5
3.1 Atelier 2 : Sources de Risque et Menaces 5
3.2 Atelier 3 : Scénarios Stratégiques 5
3.3 Atelier 4 : Scénarios Opérationnels et Kill Chain 7
4. MESURES DE SÉCURITÉ (CIS CSC v8.1) 10
4.1 Les 18 Contrôles CIS CSC v8.1 – Référence Complète 10
4.2 Développement Détaillé des Dix Contrôles Sélectionnés 10
5. MISE EN CONFORMITÉ (NIST CSF 2.0) 29
5.1 Govern (GV) – Gouvernance et Pilotage 29
5.2 Identify (ID) – Identification et Inventaire 30
5.3 Protect (PR) – Protection et Défense 30
5.4 Detect (DE) – Détection et Surveillance 31
6. ARCHITECTURE DE SÉCURITÉ 32
6.1 Zoning et Segmentation (IEC 62443) 32
6.2 Authentification et Gestion des Accès 34
7. PLAN DE TRAITEMENT DU RISQUE 36
7.1 Feuille de Route d'Implémentation 37
8. CONCLUSION 38
9. RÉFÉRENCES 39

1. INTRODUCTION

Le projet **Montfranc Smart City** vise la digitalisation et la sécurisation de la chaîne numérique de gestion intelligente de l'eau au sein d'une collectivité urbaine. Cette transformation doit garantir la disponibilité du service public, l'intégrité des données de pilotage, la confidentialité des informations citoyennes, et la conformité aux cadres réglementaires français et européens.

Ce rapport intègre une **approche holistique de sécurité** combinant trois référentiels complémentaires :

- **EBIOS RM** : analyse structurée des risques et traitement des scénarios
- **CIS CSC v8.1** : catalogue de contrôles prioritaires
- **NIST CSF 2.0** : gouvernance et pilotage de la cybersécurité
- **Architecture de sécurité cible** : implémentation concrète des mesures

L'objectif est de ramener les risques identifiés à un niveau résiduel maîtrisé, tout en préservant la continuité et la performance du service d'eau intelligent.

2. PÉRIMÈTRE ET OBJECTIFS

2.1 Définition du Périmètre

Le système étudié concerne la **chaîne numérique de gestion intelligente de l'eau** avec trois zones principales :

Zone OT/IIoT (Opérationnel Terrain)

- Capteurs IoT connectés : mesure du niveau, pression, qualité de l'eau
- Passerelles Edge Gateways : filtrage, validation, chiffrement des données
- Automates SCADA et RTU (Remote Terminal Unit) : commande distance des équipements hydrauliques (pompes, vannes, stations de traitement)
- Réseaux de terrain : LoRa, Modbus TCP, MQTT industriel

Zone IT (Informatique Bureautique)

- Postes de travail (DSI, opérateurs, support)
- Applications métier : facturation, relation client, gestion administrative
- Serveurs d'annuaire (Active Directory) et services de collaboration
- Infrastructure IT centrale de la collectivité

Zone Cloud (Supervision et Analytique)

- Portail web centralisé de supervision

- API d'accès aux données
- Modules d'analyse prédictive et d'alerte
- Data Lake : stockage historique des mesures
- PRA/PCA (Plan de Reprise/Continuité d'Activité)

2.2 Actifs Essentiels

Actif	Criticité	Justification
Capteurs IoT	**Très Élevée**	Mesure fiabilité des données terrain ; toute compromission = fausses données ou indisponibilité
Edge Gateways	**Très Élevée**	Point de convergence OT/Cloud ; perte = rupture IT-OT
SCADA/RTU	**Critique**	Commande des équipements ; toute défaillance impacte directement la santé publique
Supervision Cloud	**Critique**	Visibilité et pilotage global ; compromission = perte de contrôle du service
Données mesures	**Très Élevée**	Données environnementales, géolocalisations, consommations personnelles (RGPD)
Personnel IT/OT	**Élevée**	Techniciens, opérateurs, ingénieurs = vecteurs possibles d'erreurs humaines

2.3 Objectifs de Sécurité (SSI)

Objectif	Enjeu	Justification
Disponibilité	24/7/365	Service public essentiel ; interruption = perte de pilotage et risque sanitaire
Intégrité	Données de pilotage	Fausses mesures = mauvaises décisions = risques environnementaux/sanitaires
Confidentialité	Données citoyennes	Conformité RGPD ; perte de confiance en cas d'exposition
Authenticité	Origine des commandes	Injection de fausses données ou commandes non autorisées
Conformité	NIS2, RGPD, ANSSI IoT	Exigences réglementaires et de gouvernance

Table 1: Objectifs de Sécurité du Projet Montfranc Smart City

2.4 Cadre Réglementaire et Normes

- **RGPD** : protection des données personnelles (citoyens, consommations)
- **Directive NIS2** : résilience des infrastructures critiques (gestion de l'eau = OIV Opérateur d'Importance Vitale)
- **ANSSI IoT** : bonnes pratiques pour les objets connectés et sécurisation IoT
- **IEC 62443** : sécurisation des systèmes d'automatisation industriels (SCADA, OT)

- **ISO/IEC 27001:2022** : management global de la sécurisation de l'information
- **NIST SP 800-82r3** : sécurisation des systèmes opérationnels (OT)

3. ANALYSE DE RISQUES (EBIOS RM)

EBIOS RM (Expression des Besoins et Identification des Objectifs de Sécurité – Risques et Mesures) est la méthodologie française de référence pour l'analyse des risques SSI. Elle structure l'analyse en cinq ateliers :

- **Atelier 1** : Définition du périmètre et actifs
- **Atelier 2** : Identification des sources de risque
- **Atelier 3** : Scénarios stratégiques (impacts métiers)
- **Atelier 4** : Scénarios opérationnels (tactiques d'attaque)
- **Atelier 5** : Traitement du risque (mesures et priorités)

3.1 Atelier 2 : Sources de Risque et Menaces

Sources de Risque Identifiées :

1. Cybercriminels : exploitation de vulnérabilités pour chantage, vol de données ou sabotage
2. Hacktivistes : attaques idéologiques (DDoS, défiguration sur gestion de l'eau)
3. Employés malveillants : manipulation ou exfiltration de données
4. Sous-traitants négligents : maintenance défaillante, absence de patchs
5. États/APT : espionnage ou manipulation stratégique de données
6. Erreurs humaines : mauvaise configuration, gestion défaillante de certificats
7. Défaillances techniques : panne Cloud, obsolescence capteurs, manques d'alimentation

Menaces Principales :

- Sabotage d'infrastructures : arrêt de pompes ou ouverture de vannes à distance
- Injection de fausses données : altération de la qualité perçue de l'eau
- Blocage/DDoS : indisponibilité du système de supervision
- Fuite de données sensibles : exposition d'informations environnementales ou personnelles
- Propagation IT→OT : malware passant du SI bureautique au SCADA

3.2 Atelier 3 : Scénarios Stratégiques

Sept scénarios stratégiques (SR1–SR7) ont été identifiés, ordonnés par criticité :

Scénario SR1 : Compromission du Réseau de Capteurs IoT

- Description : Attaquant exploit une faille firmware sur capteur non mis à jour ; compromission se propage via LoRa/MQTT vers la passerelle Edge
- Impacts : indisponibilité partielle, altération des mesures, perte de confiance
- Criticité : **Très élevée**
- Acteurs probables : cybercriminels, APT
- Références mesures : M1 (cycle de vie IoT), M2 (segmentation), M7 (chiffrement TLS/DTLS)

Scénario SR2 : Fuite de Données de Consommation/Géolocalisation

- Description : Erreur humaine ou configuration défaillante expose les données dans le Cloud public
- Impacts : violation RGPD, perte de réputation, amendes
- Criticité : **Très élevée**
- Références mesures : M4 (CSPM/DLP Cloud), M3 (chiffrement au repos)

Scénario SR3 : Attaque sur les Edge Gateways

- Description : Ransomware cible les passerelles Edge, coupant le lien entre terrain et supervision
- Impacts : interruption de la chaîne de commande, risque sanitaire
- Criticité : **Critique**
- Références mesures : M1 (durcissement OS), M3 (MFA/PAM), M5 (EDR), M6 (segmentation)

Scénario SR4 : Injection de Fausses Données dans le Cloud

- Description : Acteur injecte des mesures falsifiées dans le data lake de supervision
- Impacts : fausses alertes, décisions erronées, perte d'intégrité
- Criticité : **Élevée**
- Références mesures : M1 (journalisation immuable), M8 (validation HMAC)

Scénario SR5 : Panne Majeure du Fournisseur Cloud

- Description : Panne du prestataire Cloud interrompt la supervision globale
- Impacts : perte de visibilité, arrêt du pilotage
- Criticité : **Élevée**
- Références mesures : M5 (PRA/redondance multi-région), M8 (Edge backup)

Scénario SR6 : Contamination IT→OT (Latéralisation)

- Description : Malware issu du SI bureautique atteint le SCADA via absence de segmentation

- Impacts : sabotage d'équipements, compromission de la sûreté industrielle
- Criticité : **Très élevée**
- Références mesures : M2 (pare-feu DMZ, segmentation IEC 62443), M6 (SOC/SIEM)

Scénario SR7 : Erreur Humaine sur Mise à Jour de Capteurs

- Description : Mise à jour défaillante déploie un firmware corrompu
- Impacts : perte de disponibilité, dysfonctionnements multiples
- Criticité : **Moyenne-élevée**
- Références mesures : M1 (supervision du patching, validation avant déploiement)

3.3 Atelier 4 : Scénarios Opérationnels et Kill Chain

Chaque scénario stratégique se décompose en scénarios opérationnels détaillant la chaîne tactique d'attaque.

OP1 – SR1 : Capteur IoT Compromis

1. Reconnaissance : identification des IP/adresses LoRa des capteurs exposés
2. Delivery : infection firmware via compilateur piraté ou injection firmware OTA non signée
3. Installation : malware persiste en EEPROM ou firmware
4. Propagation : capteur transmet code malveillant via LoRa/MQTT vers Edge Gateway
5. Commande/Contrôle : attaquant prend contrôle du capteur (accès distant)
6. Action : capteur envoie fausses mesures ou silencieux (indisponibilité)
7. Exfiltration : extraction de clé de chiffrement ou certificats du capteur

Vulnérabilités exploitées : absence de patchs, chiffrement faible, certificats non gérés.

Contrôles prioritaires : M1 (gestion du cycle de vie IoT, patching signé), M2 (segmentation réseau), M7 (chiffrement TLS/DTLS).

OP2 – SR3 : Compromission d'une Edge Gateway

1. Reconnaissance : scan des adresses Ethernet de passerelles exposées
2. Phishing : ciblage d'un technicien pour vol de credentials SSH
3. Exploitation : accès SSH non filtré ; exécution de binaire malveillant
4. Installation : ransomware chiffre le système de fichiers
5. Commande/Contrôle : communic vers serveur C2 attacker
6. Action : blocage du flux LoRa→Cloud ; interruption du pilotage
7. Extorsion : demande de rançon

Contrôles prioritaires : M3 (MFA obligatoire SSH), M5 (EDR embarqué), M6 (segmentation strict IT-OT).

OP3 – SR4 : Manipulation de Données Cloud

1. Reconnaissance : identification des endpoints API du Cloud
2. Exploitation : accès API non protégée ou vol de token JWT/API key
3. Injection : payload JSON modifié injecté dans le data lake
4. Persistance : modification des données historiques via SQL ou mise à jour de base
5. Impact : génération d'alertes parasites ou décisions métier erronées

Contrôles prioritaires : M1 (journalisation immuable), M8 (intégrité HMAC), M4 (authentification forte API).

OP4 – SR6 : Contamination IT→OT

1. Reconnaissance : scan du SI bureautique et identification de DMZ absente
2. Intrusion : email de phishing adressé aux DSI ; exploitation vulnérabilité bureautique
3. Latéralisation : malware IT traverse le pare-feu OT (accès direct SCADA)
4. Installation : worm se déploie sur automates SCADA
5. Action : modification de logique de commande (shutdown pompes, ouverture vannes)
6. Impact : indisponibilité du service et risque sanitaire

Contrôles prioritaires : M2 (pare-feu d'interconnexion IT→OT, segmentation, Deny All par défaut), M6 (supervision SOC).

OP5 – SR2 : Fuite de Données Environnementales

1. Reconnaissance : scan des buckets AWS/Azure du Cloud public (misconfiguration detection)
2. Exposition : bucket S3/Blob déverrouillé (ACL trop permissive)
3. Exfiltration : téléchargement des fichiers données personnelles, mesures géolocalisées
4. Exploitation : revente des données ou publication par hacktivistes
5. Impact : violation RGPD, perte de confiance citoyenne

Contrôles prioritaires : M4 (CSPM automatisé, DLP), M3 (chiffrement au repos), M7 (audit des ACL).

3.4 Atelier 5 : Traitement du Risque

La matrice de risque (brut → résiduel) synthétise l'impact des mesures de maîtrise :

Scénario	Prob. Brute	Impact	Mesures Clés	Prob. Résid.	Niveau Résiduel
SR1 – Compromission IoT	Élevée	Critique	M1, M2, M7	Moyenne	Modéré
SR2 – Fuite données	Élevée	Critique	M4, M3	Moyenne	Modéré
SR3 – Edge Gateway	Élevée	Critique	M3, M5, M6	Moyenne	Modéré
SR4 – Données falsifiées	Moyenne	Élevée	M1, M8	Faible	Faible
SR5 – Panne Cloud	Moyenne	Élevée	M5, M8	Faible	Faible
SR6 – Contamination IT→OT	Élevée	Critique	M2, M6	Moyenne	Modéré
SR7 – Erreur maj	Moyenne	Élevée	M1, M7	Faible	Faible

Table 2: Matrice de Criticité Brute et Résiduelle

Plan de Traitement du Risque (M1–M9) :

Mesure	**Domaine**	**Responsable**	**Délai**	**Priorité**
M1	Cycle de vie IoT (firmware, patchs, certificats)	Équipe IoT	3 mois	Haute
M2	Segmentation réseau IT-OT (IEC 62443)	RSSI OT	4 mois	Haute
M3	MFA et PAM sur Edge/SCADA	DSI SecOps	3 mois	Haute
M4	CSPM et DLP Cloud	CloudSecOps	2 mois	Moyenne
M5	Sauvegardes immuables et PRA/tests	Infra OT	2 mois	Moyenne
M6	SOC OT/IT et corrélation SIEM	SecOps	6 mois	Haute
M7	Sensibilisation et formation Sécurité IoT/OT	RSSI/RH	3 mois	Moyenne
M8	Redondance multi-région Cloud et Edge backup	DSI	5 mois	Moyenne
M9	Audits et Red Team annuels	RSSI	9 mois	Moyenne

Table 3: Plan de Traitement du Risque (EBIOS RM Atelier 5)

Phases d'implémentation :

- **Phase 0 (mois 1-2)** : M3, M4, M5 – Bases sécurité (MFA, chiffrement Cloud, backups)
- **Phase 1 (mois 3-4)** : M1, M2 – Cycle de vie IoT et segmentation
- **Phase 2 (mois 5-6)** : M6, M7 – Détection (SOC) et sensibilisation

- **Phase 3 (mois 7-18)** : M8, M9 – Résilience (redondance) et audits

4. MESURES DE SÉCURITÉ (CIS CSC v8.1)

Les **CIS Critical Security Controls** (CSC) v8.1 du SANS Institute fournissent un catalogue de 18 contrôles prioritaires pour réduire les risques cyber. Pour le projet Montfranc, l'ensemble des 18 contrôles est présenté ci-dessous, suivi des dix contrôles sélectionnés pour développement détaillé en fonction de la criticité du périmètre IT/OT convergent.

4.1 Les 18 Contrôles CIS CSC v8.1 – Référence Complète

CSC	Intitulé du Contrôle
1	Inventory and Control of Enterprise Assets (Inventaire et Contrôle des Actifs d'Entreprise)
2	Inventory and Control of Software Assets (Inventaire et Contrôle des Actifs Logiciels)
3	Data Protection (Protection des Données)
4	Secure Configuration of Enterprise Assets and Software (Configuration Sécurisée des Actifs et Logiciels)
5	Account Management (Gestion des Comptes)
6	Access Control Management (Gestion du Contrôle d'Accès)
7	Continuous Vulnerability Management (Gestion Continue des Vulnérabilités)
8	Audit Log Management (Gestion des Journaux d'Audit)
9	Email and Web Browser Protections (Protections Messagerie et Navigateur Web)
10	Malware Defenses (Défenses contre les Malwares)
11	Data Recovery (Récupération des Données)
12	Network Infrastructure Management (Gestion de l'Infrastructure Réseau)
13	Network Monitoring and Defense (Surveillance et Défense Réseau)
14	Security Awareness and Skills Training (Sensibilisation et Formation à la Sécurité)
15	Service Provider Management (Gestion des Prestataires de Service)
16	Application Software Security (Sécurité des Applications)
17	Incident Response Management (Gestion de la Réponse aux Incidents)
18	Penetration Testing (Tests de Pénétration)

Table 4: Les 18 Contrôles CIS CSC v8.1 – Référence Complète

4.2 Développement Détaillé des Dix Contrôles Sélectionnés

La sélection des dix contrôles suivants repose sur l'analyse EBIOS RM et la criticité du périmètre IT/OT/Cloud convergent :

i1 – Désignation du Contrôle #1

Inventory and Control of Enterprise Assets (Inventaire et Contrôle des Actifs d'Entreprise)

i-1 Objectifs du Contrôle #1

- Identifier et gérer tous les actifs physiques et virtuels (capteurs IoT, Edge Gateways, serveurs SCADA, instances Cloud)
- Minimiser les angles morts qui permettraient des attaques sur des actifs non supervisés
- Maintenir une visibilité temps réel sur l'évolution du parc IT/OT/Cloud
- Détecter les actifs non autorisés ou obsolètes

i-2 Principaux Résultats d'Application du Contrôle #1 et de ses Mesures de Sécurité sur le Périmètre Smart City

- Inventaire exhaustif des capteurs IoT déployés sur le terrain, de tous les Edge Gateways et serveurs SCADA, des instances Cloud
- Intégration avec CMDB (Configuration Management Database) pour visibilité en temps réel sur les flux IT/OT
- Réduction d'au moins 50% des risques de compromission via actifs obsolètes ou non maintenus
- Identification rapide des changements non autorisés dans le parc IoT/OT/Cloud
- Lien direct avec SR1 (capture des capteurs compromis) et SR3 (identification des Edge non configurés)

i-3 Outils et Solutions Techniques Relatifs au Contrôle #1

- **Scanners réseau** : Nessus, Qualys pour découverte automatis des actifs connectés
- **Plateforme IoT** : AWS IoT Device Management, Azure IoT Hub pour tracking des capteurs
- **CMDB** : ServiceNow pour centraliser l'inventaire et les dépendances
- **Outils de discovery passive** : sniffer réseau, logs de pare-feu pour identifier trafic OT inconnu
- **Techniques de scanage OT** : compatibles avec IEC 62443 (pas de scanning agressif qui interrompt service)

i-4 Observations

- Difficile à maintenir pour capteurs mobiles déployés en zone rurale ; nécessité d'une mise à jour trimestrielle couvrant les ajouts de nouveaux actifs
- Possibilité de « shadow IT » : capteurs déployés hors procédure ; mettre en place contrôle des connexions non autorisées

- Le découpage en zones (OT/IT/Cloud) complique l'inventaire unique ; prévoir outils/processus adaptés à chaque domaine
- Performance réseau : les scans agressifs risquent d'impacter la production OT ; utiliser découverte passive en priorité

i2 – Désignation du Contrôle #2

Inventory and Control of Software Assets (Inventaire et Contrôle des Actifs Logiciels)

i-1 Objectifs du Contrôle #2

- Gérer les logiciels installés : firmware capteurs, OS Edge, logiciels SCADA, applications Cloud
- Empêcher l'exécution de code non autorisé
- Réduire la surface d'attaque via suppression des logiciels non nécessaires
- Assurer la traçabilité des versions et des mises à jour

i-2 Principaux Résultats d'Application du Contrôle #2 et de ses Mesures de Sécurité sur le Périmètre Smart City

- Patching automatique sur au moins 80% des actifs IoT/Edge/SCADA
- Blocage des versions firmware non approuvées ; signature numérique obligatoire
- Amélioration de l'intégrité des données d'eau via firmware sécurisé
- Réduction SR1 (compromission IoT) et SR3 (ransomware Edge)
- Traçabilité complète des mises à jour firmware et détection des installations non autorisées

i-3 Outils et Solutions Techniques Relatifs au Contrôle #2

- **Gestion logiciels** : Microsoft Intune, Tanium pour inventaire et déploiement
- **Signatures numériques** : PKI interne pour signer firmware capteurs/Edge avant déploiement
- **Allowlisting applicatif** : whitelist stricte des binaires autorisés sur Edge/SCADA
- **Référentiel versions approuvées** : base CMDB listant firmware/OS validés pour chaque type de capteur
- **SIEM/Audit** : logs centralisés de toute installation logicielle (compliance)

i-4 Observations

- Appareils OT legacy (vieux SCADA) ne supportent pas toujours les outils de gestion modernes ; approche hybride (inventaire indirect + procédure manuelle)
- Firmware capteurs : signé mais impossible d'auditer le source => risque de supply chain ; validation antivirus sur tous les firmwares avant déploiement

- Containte 24/7 : patch OT risque downtime => fenêtres de maintenance planifiées + rollback automatisé en cas de dysfonctionnement
- Prioriser les actifs critiques (SCADA, Edge) pour les mises à jour sécurité ; actifs secondaires traités en second vague

i3 – Désignation du Contrôle #3

Data Protection (Protection des Données)

i-1 Objectifs du Contrôle #3

- Identifier, classifier et protéger les données sensibles contre fuites, altérations ou accès non autorisé
- Implémenter chiffrement en transit et au repos
- Appliquer contrôles d'accès et de rétention adaptés à chaque classe de données
- Assurer conformité RGPD et normes réglementaires

i-2 Principaux Résultats d'Application du Contrôle #3 et de ses Mesures de Sécurité sur le Périmètre Smart City

- Chiffrement TLS 1.2+ pour tous les flux réseau (capteurs → Edge → Cloud)
- Chiffrement AES-256 au repos sur Cloud (data lake, backups)
- Conformité RGPD : données citoyennes (consommations, géolocalisations) protégées et auditables
- DLP (Data Loss Prevention) bloque les exfiltrations de données sensibles
- Réduction SR2 (fuite Cloud) et SR4 (injection fausses données)
- Classification : mesures d'eau = public ; consommations personnelles = confidentielles (RGPD)

i-3 Outils et Solutions Techniques Relatifs au Contrôle #3

- **Chiffrement en transit** : TLS 1.2+, DTLS pour communications sans fil, IPSec pour VPN
- **Chiffrement au repos** : AES-256 via AWS KMS, Azure Key Vault ou HSM interne
- **DLP** : Symantec Data Loss Prevention, Microsoft Purview Information Protection
- **Classification données** : Azure Information Protection, AWS Macie pour découverte et classification
- **Gestion clés** : HashiCorp Vault ou CyberArk pour centralisé clés/certificats

i-4 Observations

- Volume données IoT volumineuses (millions de mesures/jour) ralentissent le chiffrement ; optimiser par segmentation (chiffrer données sensibles, compresser données publiques)
- Performance TLS sur capteurs low-power : utiliser DTLS optimisé ou pré-partagé pour réduire overhead
- Gestion clés complexe en environnement distribué (capteurs, Edge, Cloud) ; mettre en place cycle de rotation (90 jours max)
- Backups immuables (M5) doivent être chiffrés ; tester régulièrement décryptage en cas de sinistre

i4 – Désignation du Contrôle #4

Secure Configuration of Enterprise Assets and Software (Configuration Sécurisée des Actifs et Logiciels)

i-1 Objectifs du Contrôle #4

- Définir et appliquer des configurations durcies par défaut
- Désactiver ports inutiles, protocoles non nécessaires, services non utilisés
- Minimiser la surface d'attaque
- Assurer la traçabilité et le suivi de conformité des configurations

i-2 Principaux Résultats d'Application du Contrôle #4 et de ses Mesures de Sécurité sur le Périmètre Smart City

- Durcissement des Edge Gateways : OS minimal (stripped-down Linux), pas de services superflus
- Réduction d'au moins 70% de la surface d'attaque
- Conformité IEC 62443 sur tous les équipements OT
- Configuration bastion IT/OT : SSH sur port non standard, pas d'accès root direct, seulement accès PAM/bastion
- Baisse SR3 (ransomware Edge) et SR6 (latéralisation IT→OT)

i-3 Outils et Solutions Techniques Relatifs au Contrôle #4

- **Benchmarks CIS** : configurations de référence pour Linux, Windows, Cloud (AWS/Azure)
- **Automatisation** : Ansible, Puppet pour déploiement et suivi de conformité
- **Scanning conformité** : SCAP (Security Content Automation Protocol) pour vérifier configs
- **Gestion configuration** : Terraform, CloudFormation pour IaC (Infrastructure as Code)

- **Templates durcis** : images de base pré-durcies pour tous les serveurs/passerelles

i-4 Observations

- Configurations OT doivent être testées extensivement pour ne pas impacter la continuité du service d'eau critique 24/7
- Fenêtres de maintenance planifiées et validées avant tout changement config en production
- Rollback sécurisé : si config casse la continuité, revenir à config antérieure en < 30 secondes
- Documentation exhaustive de toute exception (ex: port autorisé pour besoin spécifique) avec justification métier et sécurité

i5 – Désignation du Contrôle #5

Account Management (Gestion des Comptes)

i-1 Objectifs du Contrôle #5

- Créer, gérer et désactiver les comptes utilisateurs et comptes de service
- Implémenter le cycle de vie complet (joiner-mover-leaver)
- Déterminer et documenter les besoins en accès pour chaque rôle
- Réduire les accès de facto non justifiés

i-2 Principaux Résultats d'Application du Contrôle #5 et de ses Mesures de Sécurité sur le Périmètre Smart City

- Gestion centralisée de tous les comptes IT et Cloud via Identity Provider (IdP)
- Réduction des accès résiduels après départ d'un salarié (leaver = désactivation immédiate)
- Comptes de service : gestion via Vault centralisé avec rotation régulière (30 jours)
- Lien M3 (MFA) : tout compte privilégié nécessite MFA + comptes OT séparés d'IT
- Prévention SR2 (accès Cloud non autorisé via compte résiduel)

i-3 Outils et Solutions Techniques Relatifs au Contrôle #5

- **IAM/IdP** : Okta, Azure AD, Keycloak pour gestion centralisée
- **Gestion cycle de vie** : JML (Joiner-Mover-Leaver) automats via workflows
- **PAM** : HashiCorp Vault, CyberArk pour gestion comptes privilégiés
- **Audit d'accès** : revues trimestrielles des droits via rapports IAM
- **Séparation des domaines** : annuaire OT ≠ IT (pas d'AD partagé pour admin OT)

i-4 Observations

- Multi-acteurs (collectivité, exploitant eau, intégrateurs) → contrats SSI spécifiant gestion d'accès
- Comptes de service non supervisés = risque : tous les comptes de service doivent être en PAM avec logs complets
- Absence de gestion OT dédiée = risque de réutilisation comptes IT ; mettre en place annuaire OT séparé
- Audit d'accès : minimum semestriel ; recommandé trimestriel pour comptes privilégiés

i6 – Désignation du Contrôle #6

Access Control Management (Gestion du Contrôle d'Accès)

i-1 Objectifs du Contrôle #6

- Limiter les accès aux ressources via RBAC (Role-Based Access Control)
- Appliquer le principe du privilège minimum (least privilege)
- Implémenter segmentation réseau et micro-segmentation
- Réviser régulièrement les autorisations et supprimer les accès obsolètes

i-2 Principaux Résultats d'Application du Contrôle #6 et de ses Mesures de Sécurité sur le Périmètre Smart City

- RBAC sur SCADA : rôles distincts pour opérateurs (lecture), techniciens (config), administrateurs (complet)
- RBAC sur Cloud : rôles data-engineer, analyst, admin ; isolation des environnements dev/staging/prod
- Empêchement de latéralisation IT→OT via pare-feu + segmentation + privilèges minimums
- Réduction des erreurs humaines par limitation du contexte d'exécution (quel admin peut faire quoi ?)
- Baisse SR6 (contamination) et SR3 (ransomware via accès privilégié)

i-3 Outils et Solutions Techniques Relatifs au Contrôle #6

- **RBAC** : Active Directory (IT), annuaire OT dédié (LDAP sécurisé)
- **Zero Trust** : Okta, Zscaler pour accès conditionnel basé sur contexte
- **PAM** : CyberArk, HashiCorp pour accès privilégés avec enregistrement vidéo sessions
- **Segmentation réseau** : pare-feu, ACL VLAN par rôle/zone
- **Monitoring accès** : logs de toute tentative (succès/refus) intégrés SIEM

i-4 Observations

- Complexe avec multi-acteurs (collectivité, sous-traitants, prestataires Cloud) ; nécessité de contrats clarifiant les rôles et responsabilités
- Audits d'accès réguliers critiques : prévoir revues mensuelles pour comptes privilégiés, semestrielles pour autres
- Isolation comptes OT vs IT indispensable : jamais partager AD entre zones
- Documenter les exceptions (ex: pourquoi tel opérateur a accès à telle vanne) et revalider trimestriellement

i7 – Désignation du Contrôle #7

Continuous Vulnerability Management (Gestion Continue des Vulnérabilités)

i-1 Objectifs du Contrôle #7

- Scanner les systèmes et applications pour identifier les vulnérabilités
- Qualifier et prioriser par CVSS et contexte métier
- Corriger et patcher en continu avec SLA clair
- Suivre l'information de vulnérabilités (CVE, advisories OT/ICS)

i-2 Principaux Résultats d'Application du Contrôle #7 et de ses Mesures de Sécurité sur le Périmètre Smart City

- Patching firmware IoT atténuant SR1
- CVSS 7+ patchés dans les 30 jours (fenêtres OT planifiées)
- Intégration SOC : alertes vulnérabilités détectées = escalade RSSI
- Suivi des CVE/ICS-CERT et prévention proactive
- Baisse significative du vecteur « absence de patch » dans kill chain attaquant

i-3 Outils et Solutions Techniques Relatifs au Contrôle #7

- **Scanners vulnérabilités** : Tenable Nessus, Rapid7 InsightVM pour IoT/Cloud/OT
- **Suivi CVE** : abonnements NVD (National Vulnerability Database), ICS-CERT alerts ANSSI
- **Automatisation patching** : Puppet, Ansible pour déploiement sécurisé
- **Tests pré-déploiement** : environnement de staging reproduisant production avant patch OT
- **Rollback** : snapshot/image de base pour revenir en cas de dysfonctionnement patch

i-4 Observations

- Patching OT critique risque indisponibilité service eau ; utiliser fenêtres de maintenance strictement planifiées (ex: dimanche 2h-4h)
- Compromis performance/sécurité : pas possible de patcher capteur low-power à distance => compenser via segmentation + supervision

- Firmware capteurs : difficile à auditer l'évolution des vulnérabilités ; préférer constructeurs ayant bonne politique de patch
- Gestion dette technique : certains actifs legacy sans patch possible => acceptation risque documentée + compensations (segmentation, IDS)

i8 – Désignation du Contrôle #8

Audit Log Management (Gestion des Journaux d'Audit)

i-1 Objectifs du Contrôle #8

- Collecter, centraliser, alerter sur les événements importants
- Assurer l'immuabilité et la rétention longue des logs
- Faciliter les investigations post-incident et audits de conformité
- Permettre la corrélation de événements pour détecter pattern d'attaque

i-2 Principaux Résultats d'Application du Contrôle #8 et de ses Mesures de Sécurité sur le Périmètre Smart City

- Logs centralisés de toutes les zones IT/OT/Cloud dans SIEM (Splunk, ELK)
- Traçabilité complète « qui/quand/quoi » pour toute action critique (accès SCADA, changement config, etc.)
- Identification fast de patterns attaque via corrélation événements
- Facilitation enquête SR2 (fuite données), SR3 (ransomware), SR6 (latéralisation)
- Conformité audit : logs fournis aux enquêteurs ANSSI en cas d'incident

i-3 Outils et Solutions Techniques Relatifs au Contrôle #8

- **Syslog/collecteurs** : rsyslog, Fluentd, Logstash pour ingestion centralisée
- **SIEM** : Splunk, ELK (Elasticsearch), Graylog pour agrégation et recherche
- **Synchronisation temps** : NTP sur tous les systèmes (horodatage fiable)
- **Immuabilité** : logs archivés en WORM (Write Once Read Many) ou stockage immuable Cloud
- **Rétention** : minimum 12 mois pour logs critiques ; 3 ans pour données sensibles (RGPD)
- **Alertes** : règles de corrélation détectant événements suspects (accès échoué répété, modification config non autorisée)

i-4 Observations

- Volume énorme de logs IoT/OT (millions d'événements/jour) => filtrage/normalisation essentiels pour pertinence
- Cas d'usage prioritaires : accès administrateur, changements configuration, tentatives non autorisées, anomalies réseau

- Stockage long-terme logs OT : coût significatif ; arbitrer entre rétention légale et budget
- Confidentialité logs : contiennent données sensibles (identités, commandes) => accès restreint, chiffrement en transit/repos

i9 – Désignation du Contrôle #9

Email and Web Browser Protections (Protections Messagerie et Navigateur Web)

i-1 Objectifs du Contrôle #9

- Réduire les menaces entrantes via email (phishing, malware, ransomware)
- Sécuriser la navigation web et bloquer sites malveillants
- Appliquer les standards DMARC/DKIM/SPF pour authentification email
- Éduquer les utilisateurs sur les risques de phishing/social engineering

i-2 Principaux Résultats d'Application du Contrôle #9 et de ses Mesures de Sécurité sur le Périmètre Smart City

- Baisse du vecteur « phishing IT » pouvant mener à SR6 (contamination IT→OT)
- Blocage 95%+ des emails de phishing/malveillants via passerelle sécurisée
- Prévention du vecteur « malware email → IT → rebond OT » documenté dans OP4
- Réduction SR3 (ransomware via email vers technicien) et SR6 (latéralisation)
- Simulation phishing régulières pour tester et former personnel

i-3 Outils et Solutions Techniques Relatifs au Contrôle #9

- **Passerelle email** : Proofpoint, Mimecast, Microsoft Defender for Office 365
- **Anti-phishing** : détection URLs malveillantes, sandboxing email, machine learning
- **DMARC/DKIM/SPF** : configuration domaines pour valider authentification email
- **Proxy web** : Zscaler, Fortinet FortiProxy pour filtrage URL et détection malware web
- **Isolation navigateur** : browser isolation pour sites suspects (containers séparé pour chaque tab)
- **Simulations phishing** : KnowBe4, Gophish pour tests réguliers et métriques

i-4 Observations

- Cible fréquente = techniciens/opérateurs IT/OT ; l'efficacité dépend fortement de formation continue (lien CSC 14)
- Faux positifs (emails légitimes bloqués) = frustration utilisateurs ; tuning nécessaire entre sécurité et usabilité
- Personnel OT souvent moins formé à risques cyber ; communication/sensibilisation adaptée au public

- Taux cliquage phishing simulé = KPI de formation ; réduire progressivement via répétitions et feedbacks

i10 – Désignation du Contrôle #10

Malware Defenses (Défenses contre les Malwares)

i-1 Objectifs du Contrôle #10

- Prévenir et détecter l'installation et l'exécution de malwares
- Déployer EPP (Endpoint Protection Platform) et EDR (Endpoint Detection & Response)
- Implémenter allowlisting applicatif pour exécution contrôlée
- Bloquer exploitation d'exploitation d'outils légitimes (living-off-the-land)

i-2 Principaux Résultats d'Application du Contrôle #10 et de ses Mesures de Sécurité sur le Périmètre Smart City

- EDR sur Edge Gateways et serveurs SCADA critiques -> détection ransomware atténue SR3
- Détection 90%+ des malwares grâce à signature + comportement
- Allowlisting strict sur Edge/SCADA : seuls exécutables autorisés peuvent tourner
- Intégration SIEM : alertes EDR corélées avec autres événements pour détection kill chain
- Baisse SR3 (ransomware) et SR6 (malware IT propagé vers OT)

i-3 Outils et Solutions Techniques Relatifs au Contrôle #10

- **EPP/EDR** : CrowdStrike Falcon, Microsoft Defender for Endpoint, SentinelOne
- **EDR OT-spécialisé** : Microsoft Defender for IoT, Fortive Nozomi
- **Allowlisting** : application whitelist strict sur serveurs critiques (SCADA, Edge)
- **Sandboxing** : détonation de fichiers suspects dans environnement isolé avant exécution
- **YARA/Snort rules** : signatures comportementales pour détecter ransomware, worms
- **Isolement navigateur/plugins** : macros désactivées, plugins sécurisés

i-4 Observations

- Capteurs low-power (IoT embarqué) : impossible d'installer EDR -> compenser via segmentation réseau stricte + supervision trafic (NDR)
- Allowlisting strict = immuable binaires => risque de légitime bloqué ; mise à jour allowlist critique

- Ransomware OT cible : volumes élevés chiffrement => préférer offline detection (EDR logs offline) + offline backups (M5)
- False positives EDR = fatigue opérateurs ; tuning comportements nécessaire pour ne pas noyer analysts

i11 – Désignation du Contrôle #11

Data Recovery (Récupération des Données)

i-1 Objectifs du Contrôle #11

- Assurer sauvegardes régulières de tous les actifs critiques
- Implémenter immuabilité (WORM) pour protection ransomware
- Tester récupération régulièrement (RTO/RPO)
- Documenter et publier plans de reprise activité (PRA)

i-2 Principaux Résultats d'Application du Contrôle #11 et de ses Mesures de Sécurité sur le Périmètre Smart City

- Backups immuables Cloud stockés multi-région (EU + secours hors-EU si besoin)
- Protection contre ransomware SR3 : si Edge crypté, récupération à partir backup immuable
- RTO cible 4h : supervision eau restaurée en 4h max après incident
- RPO cible 1h : maximum 1h de données perdues en cas d'incident
- Tests PRA trimestriels avec basculement complet validant RTO/RPO
- Lien M8 (redondance Cloud) : architecture multi-région tolérant panne datacenter

i-3 Outils et Solutions Techniques Relatifs au Contrôle #11

- **Backup Cloud** : AWS Backup, Azure Backup avec options multi-région
- **Immuabilité WORM** : protection ransomware via Write Once Read Many
- **Veeam** : sauvegarde VMware/Hyper-V avec récupération granulaire
- **Edge backup local** : cache local sur Edge secondaire en redondance
- **Test restauration** : lab isolé reproduisant production pour validation sans risque
- **Orchestration PRA** : automation du basculement Cloud via IaC (Terraform, Ansible)

i-4 Observations

- Tester PRA sans casser production : utiliser environnement staging ou basculement « shadow » (données anciennes)
- Coût multi-région : justifié par criticité service eau ; documente dans budget SSI

- Clés de déchiffrement backups immuables : stocker séparément (Vault HSM) pour récupération en cas perte clés
- Documentation PRA/RTO/RPO : mise à jour annuelle minimum ; communication claire aux managers métier sur SLA

i12 – Désignation du Contrôle #12

Network Infrastructure Management (Gestion de l'Infrastructure Réseau)

i-1 Objectifs du Contrôle #12

- Gérer activement les équipements réseau (routeurs, switches, pare-feu)
- Réduire l'exploitation de services vulnérables (SNMPv2, telnet, etc.)
- Implémenter segmentation et isolation des zones critiques
- Monitorer la conformité des configurations réseau

i-2 Principaux Résultats d'Application du Contrôle #12 et de ses Mesures de Sécurité sur le Périmètre Smart City

- Segmentation IT/OT/Cloud selon IEC 62443 en zones avec conduits contrôlés
- DMZ d'interconnexion IT-OT avec pare-feu dédié et bastion
- Flux whitelists strictes (deny all, accept only necessary)
- Atténuation SR6 (contamination IT→OT) via pare-feu dinterconnexion
- Audit de conformité réseau : vérification VLAN, ACL, routage

i-3 Outils et Solutions Techniques Relatifs au Contrôle #12

- **Segmentation** : Cisco ACI, Palo Alto Networks, FortiGate pour zoning
- **NAC (Network Access Control)** : contrôle d'accès au réseau par device/user
- **Gestion configuration** : Terraform, Ansible pour déploiement policies pare-feu
- **Monitoring réseau** : Cisco DNA Center, NetMRI pour compliance configurations
- **Backup configs** : sauvegarde des configurations pare-feu/routeurs pour restauration rapide
- **Bastion/Jump-server** : durci (CIS Benchmark) pour accès admin réseau

i-4 Observations

- En OT, préférer « deny by default / allowlist » plutôt que « permit by default / blacklist »
- Protocoles OT spécifiques (Modbus, OPC-UA) : vérifier support pare-feu avant déploiement
- Coût segmentation réseau legacy : ROI justifié par criticit infrastructure eau

- Maintenance réseau OT : coordination avec opérateurs ; feuille d'arrêt signée avant changement

i13 – Désignation du Contrôle #13

Network Monitoring and Defense (Surveillance et Défense Réseau)

i-1 Objectifs du Contrôle #13

- Surveiller activement le trafic réseau et détecter anomalies
- Implémenter IDS/IPS pour bloquer attaques
- Collecter NetFlow et logs réseau pour investigation post-incident
- Baseliner comportement normal vs attaque

i-2 Principaux Résultats d'Application du Contrôle #13 et de ses Mesures de Sécurité sur le Périmètre Smart City

- NDR (Network Detection & Response) détecte trafic OT suspect : exfiltration données, scans ports, C2
- IDS/IPS bloque attaques réseau : payload malveillants, protocoles non-standard
- Réduction du temps de détection SR1, SR2, SR6 via analyse comportement
- NetFlow pour corrélation : détection latéralisation via analyse flux inhabituel IT→OT
- Baselining : profil trafic normal pour chaque zone (captures SCADA, APIs)

i-3 Outils et Solutions Techniques Relatifs au Contrôle #13

- **NDR (Network Detection & Response)** : Darktrace, Vectra pour détection anomalies
- **IDS/IPS** : Suricata, Snort, Zeek pour inspection trafic
- **Sondes OT spécialisées** : Nozomi, Fortive, Claroty pour surveillance ICS/OT
- **NetFlow collectors** : Cisco, SolarWinds pour visualisation flux
- **SIEM intégration** : logs NetFlow/IDS/IPS -> SIEM pour corrélation
- **Threat intel feeds** : abonnements CVE/ICS-CERT pour signatures actualisées

i-4 Observations

- Baselining indispensable : distinguer trafic opérationnel normal (SCADA périodique) vs attaque
- Performance IDS/IPS : risque ralentissement réseau OT => placement offline ou bypass sécurisé
- Faux positifs NDR : fine-tuning règles pour pertinence sans bruit
- Sonde OT-spécialisée : détecte protocoles industriels (Modbus, OPC-UA, MQTT) mieux que IDS générique

i14 – Désignation du Contrôle #14

Security Awareness and Skills Training (Sensibilisation et Formation à la Sécurité)

i-1 Objectifs du Contrôle #14

- Programme sensibilisation continu adapté à tous les rôles
- Formation spécialisée OT/IoT pour opérateurs/techniciens
- Simulations phishing pour tester et remédier aux risques comportement
- Documenter incidents résultant erreurs humaines pour feedback

i-2 Principaux Résultats d'Application du Contrôle #14 et de ses Mesures de Sécurité sur le Périmètre Smart City

- Réduction SR7 (erreur humaine maj capteurs) via formation déploiement sécurisé
- Baisse SR6 (latéralisation) via sensibilisation phishing : personnel IT vigilant = moins de compromission
- Taux cliquage phishing simulé : cible < 5% after 6 mois formation
- Gestes sûrs OT : procédures USB, accès physique, MFA, isolation administrateur
- Fiches réflexes incident : papier/affichage en salle serveur pour référence rapide

i-3 Outils et Solutions Techniques Relatifs au Contrôle #14

- **E-learning** : KnowBe4, Proofpoint Security Awareness pour modules auto-paced
- **Phishing simulations** : campagnes mensuelles avec feedback personnalisé
- **Formations spécialisées** : SCADA security (IEC 62443), IoT lifecycle, incident response
- **Ateliers présentiels** : annuels pour collectivité + prestataires (ex: "sécurité capteurs terrain")
- **Documentation** : fiches gestes, procédures d'escalade, numéro hotline crise
- **Métriques** : nombre formations complétées, taux phishing cliqués, incidents "erreur humain"

i-4 Observations

- Formation OT nécessite approche dédiée : pas même contenu IT/bureautique ; risques métier différents
- Engagement management : sans soutien direction, formation perçue comme "obligation cosmétique"
- Multi-acteurs (collectivité, sous-traitants) : coordination formation via gouvernance SSI
- Retour d'expérience incidents : email post-incident au personnel impliqué avec leçons apprises

i15 – Désignation du Contrôle #15

Service Provider Management (Gestion des Prestataires de Service)

i-1 Objectifs du Contrôle #15

- Évaluer fournisseurs Cloud, intégrateurs, sous-traitants sur critères SSI
- Insérer exigences de sécurité dans contrats SLA
- Auditer régulièrement le respect des engagements SSI
- Gérer les dépendances et risques liés aux prestataires

i-2 Principaux Résultats d'Application du Contrôle #15 et de ses Mesures de Sécurité sur le Périmètre Smart City

- Réduction SR5 (panne Cloud) via SLA fournisseur : garantie disponibilité 99.95%, RTO/RPO
- Réduction SR2 (fuite Cloud) via audit conformité Cloud (SecNumCloud, ISO 27001)
- Contrats intégrateurs/maintenance spécifiant sécurité : audit SOC, accès bastion, MFA obligatoire
- Gouvernance multi-acteurs : COPIL sécurité impliquant collectivité, exploitant eau, intégrateurs
- Matrice RACI claire : qui fait quoi en cas d'incident

i-3 Outils et Solutions Techniques Relatifs au Contrôle #15

- **Questionnaires SSI** : VRM (Vendor Risk Management), ISO 27001 checklists
- **Audits Cloud** : SecNumCloud (France), SOC 2 Type II (international)
- **Contrats SSI** : clauses sécurité données, audit droits, breach notification
- **Matrice RACI** : documentation rôles/responsabilités par scénario d'incident
- **Monitoring prestataire** : accès à dashboards prestataire pour compliance (uptime, incidents, patches)
- **Audit tiers** : auditeur externe validant conformité SSI contrats/SLA

i-4 Observations

- Écosystème complexe Smart City : collectivité + exploitant eau + intégrateurs + Cloud + maintenance => gouvernance structurée
- Sous-traitants maintenances : négocier d'accès sécurisés (bastion, MFA, isolation réseau)
- SLA Cloud : important négocier clauses de résiliation si breach sécurité, changement stratégie pricing

- Audit prestataire : annuel minimum pour conformité, plus souvent si incident antérieur

i16 – Désignation du Contrôle #16

Application Software Security (Sécurité des Applications)

i-1 Objectifs du Contrôle #16

- Intégrer la sécurité dans le cycle de développement (SDLC) des applications
- Tester les applications (SAST/DAST) pour vulnérabilités
- Gérer les secrets (clés API, certificats) de façon sécurisée
- Surveiller et patcher les dépendances open-source vulnérables

i-2 Principaux Résultats d'Application du Contrôle #16 et de ses Mesures de Sécurité sur le Périmètre Smart City

- API Cloud sécurisée : authentification forte, rate limiting, validation inputs
- Réduction SR4 (injection fausses données) via validation données et HMAC
- Portail supervision durci : protection OWASP Top 10 (injection SQL, XSS, CSRF)
- Modules analytique : accès restreint par RBAC, logs auditables
- Dépendances open-source : SBOM (Software Bill of Materials) et scanning vulnérabilités

i-3 Outils et Solutions Techniques Relatifs au Contrôle #16

- **SAST (Static)** : SonarQube, Fortify pour analysis code avant compilation
- **DAST (Dynamic)** : Burp Suite, OWASP ZAP pour pentest applications en exécution
- **Gestion secrets** : HashiCorp Vault pour clés API, certificats clients
- **Scanning dépendances** : Snyk, OWASP Dependency-Check pour vulnérabilités npm/maven
- **WAF (Web Application Firewall)** : Cloudflare, Imperva, AWS WAF pour filtrage requêtes
- **API Gateway** : contrôle d'accès, rate limiting, monitoring
- **SBOM** : generation automatique Software Bill of Materials (cyclonedx, spdx)

i-4 Observations

- API Smart City critique = point d'entrée pour SR4 (injection données) ; security by design obligatoire
- Portail supervision : cible fréquente pour phishing/session hijacking => MFA + hardening navigateur

- Dépendances open-source : logs de qui a déployé quelle version (traçabilité supply chain)
- Pénétration interne : Red Team teste API/portail => feedback développeurs

i17 – Désignation du Contrôle #17

Incident Response Management (Gestion de la Réponse aux Incidents)

i-1 Objectifs du Contrôle #17

- Planifier la réponse aux incidents avec roles, responsabilités, escalade
- Documenter playbooks par type d'incident (ransomware, fuite données, sabotage)
- Tester les procédures via exercices réguliers (table-top, Red Team)
- Assurer coordination avec ANSSI, régulateurs et usagers en cas d'incident majeur

i-2 Principaux Résultats d'Application du Contrôle #17 et de ses Mesures de Sécurité sur le Périmètre Smart City

- Playbooks documentés pour SR1–SR7 : actions à prendre, qui contacter, quand arrêter service
- Temps de rponse cible 1h pour incidents critiques (SR3, SR6, SR5)
- Coordination multi-acteurs : COPIL crise activé immédiatement
- Communication usagers : annonce impacte sur distribution eau, ETA restauration
- Escalade ANSSI : hotline crise + déclaration incident de sécurité si applicable NIS2
- Traçabilité : tous les incidents enregistrés, analysés post-mortem pour leçons apprises

i-3 Outils et Solutions Techniques Relatifs au Contrôle #17

- **Runbooks/Playbooks** : documentation étape-par-étape par type d'incident
- **SOAR** : Splunk Phantom, Demisto pour orchestration automatisée IR
- **Hotline crise** : numéro d'urgence accessible 24/7, transfert automatisé ANSSI si besoin
- **Cellule crise** : salle réunion avec plans accrochés, contacts imprimés
- **Exercices Red Team** : annuels pour valider procédures et timing
- **Post-mortems** : réunion systématique < 72h après incident majeur ; feedback personnel impliqué
- **Incident tracker** : base de données incidents avec correlations, metrics

i-4 Observations

- En OT, répondre à incident sans arrêter service critique = défi ; décisions hard "isolation vs continuité"

- Formation IR nécessaire : personnel ne s'improvise pas forensicien ; simulation annuelle validant timing
- Communication crise : message pré-rédigé pour usagers (pas de "pas d'info" = perte confiance)
- Partenariat ANSSI : vérifier accès hotline crise avant besoin ; autorisation OIV = accès prioritaire

i18 – Désignation du Contrôle #18

Penetration Testing (Tests de Pénétration)

i-1 Objectifs du Contrôle #18

- Tester effectivité des contrôles de sécurité via attaques simulées
- Identifier vulnérabilités non détectées par scans (logique métier, chaînes d'attaque complexes)
- Valider capacité équipe à détecter et répondre à attaques
- Fournir données pour priorités d'amélioration

i-2 Principaux Résultats d'Application du Contrôle #18 et de ses Mesures de Sécurité sur le Périmètre Smart City

- Pentest IT annuel : validation DMZ, bastion, segmentation IT-OT, phishing
- Pentest Cloud annuel : API security, data access controls, misconfiguration
- Red Team OT simulé (encadré, déclaré, avec supervisors) : validation IEC 62443, EDR, SOC detection
- Tests d'intrusion IoT : tentative connexion non-autorisée capteurs, exploitation firmware
- Validation scénarios de risque SR1–SR7 : peuvent-ils être exploités ? à quelle vitesse ?
- Rapport avec recommandations implémentées en 6–12 mois

i-3 Outils et Solutions Techniques Relatifs au Contrôle #18

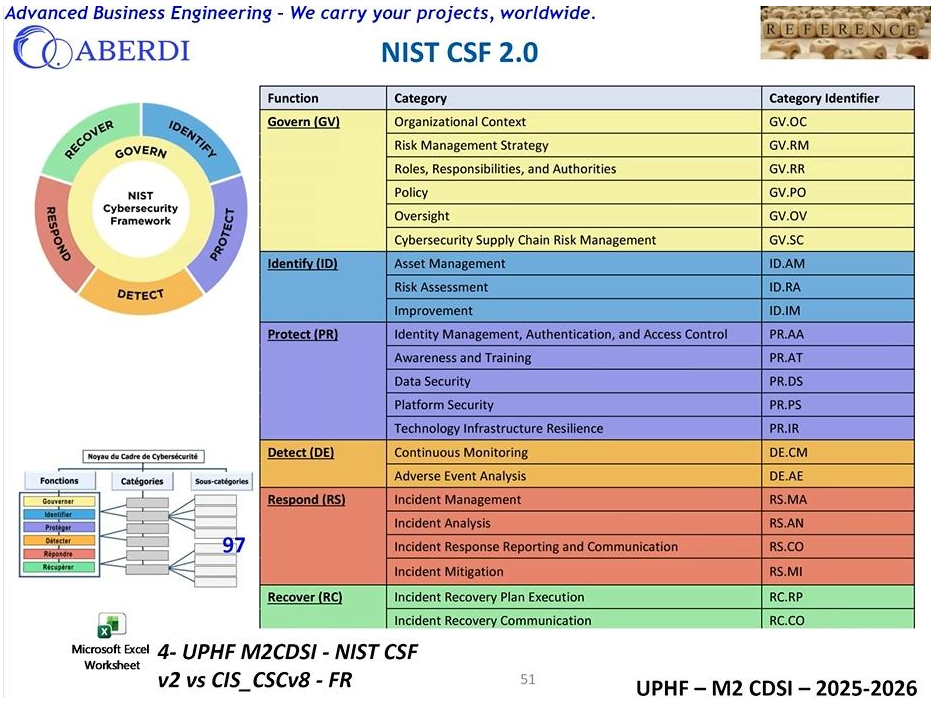
- **Pentest IT/Cloud** : Nessus, Burp, Metasploit pour exploitation technique
- **Pentest OT encadré** : avec vendor capteur/SCADA validation avant déploiement
- **Red Team purple** : intermédiaire entre Red (attaque) et Blue (défense) ; collaboration détection
- **Phishing pentest** : KnowBe4, Gophish pour simulations email
- **Gestion résultats** : ticket system pour traçabilité recommendations => remediations
- **Retro spécifique OT** : accès contrôlé au rapport; ne pas diffuser tactiques au-delà besoin-à-savoir

i-4 Observations

- Pentest OT critique : doit être STRICTEMENT CADRÉ (fenêtres d'accès, périmètre limité, supervisor présent) pour ne pas casser production
- Choix prestataire pentest : certifications (OSCP, GWAPT), expérience OT/ICS, confidentialité contrat
- Résultats pentest : actions correctives planifiées sous 6 mois ; priorité donnée aux découvertes critiques (exploitation facile, impact élevé)
- Apprentissage organisationnel : leçons apprises partagées avec équipe IT/OT pour amélioration continue

5. MISE EN CONFORMITÉ (NIST CSF 2.0)

Le **NIST Cybersecurity Framework (CSF) 2.0** fournit une structure de gouvernance cybersécurité organisée autour de cinq fonctions principales (et une sixième "Govern" en 2.0). Ce cadre permet de piloter et consolider l'ensemble des mesures dans une approche holistique.



Function	Category	Category Identifier
Govern (GV)	Organizational Context	GV.OC
	Risk Management Strategy	GV.RM
	Roles, Responsibilities, and Authorities	GV.RR
	Policy	GV.PO
	Oversight	GV.OV
	Cybersecurity Supply Chain Risk Management	GV.SC
Identify (ID)	Asset Management	ID.AM
	Risk Assessment	ID.RA
	Improvement	ID.IM
Protect (PR)	Identity Management, Authentication, and Access Control	PR.AA
	Awareness and Training	PR.AT
	Data Security	PR.DS
	Platform Security	PR.PS
	Technology Infrastructure Resilience	PR.IR
Detect (DE)	Continuous Monitoring	DE.CM
	Adverse Event Analysis	DE.AE
Respond (RS)	Incident Management	RS.MA
	Incident Analysis	RS.AN
	Incident Response Reporting and Communication	RS.CO
	Incident Mitigation	RS.MI
Recover (RC)	Incident Recovery Plan Execution	RC.RP
	Incident Recovery Communication	RC.CO

Figure 1: NIST CSF 2.0 – Les Cinq Fonctions Principales

5.1 Govern (GV) – Gouvernance et Pilotage

Objectif : Établir la gouvernance SSI, la stratégie et l'organisation pour supporter la cybersécurité.

Actions menées :

- Définition de la politique sécurité IoT/OT : standards minimaux pour tous les nouveaux capteurs

- Nomination d'un RSSI (Responsable Sécurité) dédié au projet avec pilotage mensuel
- Mise en place d'un COPIL (Comité de Pilotage) Sécurité avec représentants métier, IT, OT et Direction
- Définition des rôles et responsabilités contractuels avec tous les intervenants (collectivité, exploitant eau, intégrateurs, prestataires Cloud)
- Documentation des procédures de gestion de crise et plans de communication vers usagers
- Budget SSI alloué : mesures M1–M9 financées sur 18 mois

Références EBIOS : M1–M9 sont pilotés par la gouvernance ; décisions stratégiques de traitement du risque.

5.2 Identify (ID) – Identification et Inventaire

Objectif : Maintenir un inventaire exhaustif de tous les actifs critiques et comprendre les dépendances.

Actions menées :

- Scanner réseau automatisé (Nessus, Qualys) pour découverte capteurs et Edge (CSC 1)
- Inventaire Cloud via CSPM (Cloud Security Posture Management) pour visibilité ressources dynamiques
- Cartographie manuelle des flux métier et dépendances IT/OT
- Base CMDB (Configuration Management Database) mise à jour trimestriellement
- Identification des données critiques (mesures eau, données citoyennes RGPD)
- Classification des actifs par criticité (Très Élevée, Critique, Élevée)

Références EBIOS : M1 (cycle de vie IoT inclut inventaire) ; couvre scénarios SR1, SR3.

5.3 Protect (PR) – Protection et Défense

Objectif : Mettre en oeuvre des mesures de défense pour prévenir ou atténuer les attaques.

Actions menées :

- **Segmentation (M2)** : Zoning OT/IT/Cloud selon IEC 62443 ; pare-feu d'interconnexion IT-OT ; DMZ avec bastion durci
- **Authentification (M3)** : MFA obligatoire sur tous les accès administrateur Edge/SCADA ; PAM pour gestion centralisée des secrets
- **Chiffrement (M7)** : TLS 1.2+ pour tous les flux réseau ; DTLS pour communications sans fil capteurs ; AES-256 au repos
- **Gestion des Accès (CSC 6)** : RBAC strict sur SCADA, Cloud et bastion ; isolation des comptes OT vs IT ; rotation mots de passe 90 jours

- **Durcissement (CSC 4)** : CIS Benchmarks appliqués Edge Gateways ; désactivation services inutiles ; minimisation surface d'attaque
- **Sensibilisation (M9)** : Formation sécurité IoT/OT pour personnel IT/OT ; phishing simulations
- **Gestion des données (CSC 3)** : classification, chiffrement, DLP, audit accès

Références EBIOS : M1–M4, M7 ; couvre scénarios SR1–SR3, SR6.

5.4 Detect (DE) – Détection et Surveillance

Objectif : Déployer outils et processus pour identifier rapidement les incidents et anomalies.

Actions menées :

- **SOC OT/IT (M6)** : Centre de supervision centralisé intégrant SIEM Splunk ou ELK
- **Monitoring** :
  - Capteurs/Edge : hausse erreurs transmission, certificats expirant, firmware obsolète
  - SCADA : tentatives accès échouées, commandes non autorisées, écritures sur données critiques
  - Flux réseau : requêtes vers adresses non autorisées, protocoles suspects, débits anormaux
  - Cloud : accès heures inhabituelles, téléchargements massifs, modifications ACL
- **EDR** : Agents Endpoint Detection & Response sur Edge Gateways et serveurs critiques (CSC 10)
- **NDR** : Network Detection & Response pour détection anomalies trafic
- **Alertes automatisées** : Certificat expirant, tentative SSH échouée, modification configuration non autorisée, trafic anormal
- **Tableaux de bord** : KPI en temps réel : nombre capteurs en service, incidents/jour, patching coverage, etc.

Références EBIOS : M6 (SOC) ; détecte scénarios SR1–SR7.

5.5 Respond (RS) – Réponse et Mitigation

Objectif : Minimiser l'impact d'un incident par réponse rapide et coordonnée.

Actions menées :

- **Playbooks d'incident** : Documents par type (ransomware, fuite données, latéralisation, IoT compromis)

- **Définition des rôles** : Qui contacte ? Qui doit arrêter un service critique ? Qui alerte ANSSI et régulateurs ?
- **Exercices Red Team annuels** : Valider procédures d'IR et temps de réponse (cible : 1h pour incidents SR1–SR3)
- **Communication crise** : Scripts pré-rédigés pour annonce usagers, médias, régulateurs
- **Escalade** : Hotline crise avec accès direct ANSSI (autorisation OIV)
- **Coordination multi-acteurs** : COPIL crise mobilisé immédiatement

Références EBIOS : M10 (Incident Response planifié) ; réduction impact SR1–SR7.

5.6 Recover (RC) – Récupération et Résilience

Objectif : Rétablir services et données après incident, en minimum de temps.

Actions menées :

- **Sauvegardes immuables (M5)** : Backups Cloud + Edge en redondance ; immunité contre ransomware
- **PRA/PCA tests** : Trimestriels avec basculement complet Cloud multi-région
- **Edge Gateways redondants** : Si l'un compromis/indisponible, basculer sur le second automatiquement
- **Contrat SLA** : Cloud fournisseur garantit RTO (Recovery Time Objective) 4h et RPO (Recovery Point Objective) 1h
- **Remédiations** : Procédure réinitialisation firmware pour capteur compromis
- **Post-mortems** : Analyse rapide des incidents pour prévention future

Références EBIOS : M5 (PRA), M8 (redondance) ; couvre scénarios SR3, SR5.

6. ARCHITECTURE DE SÉCURITÉ

L'architecture cible repose sur trois principes fondamentaux :

1. **Défense en profondeur** : Multiples couches de contrôle (authentification, chiffrement, segmentation, monitoring)
2. **Zero Trust** : Aucun accès de confiance implicite ; tout accès authentifié, autorisé et vérifié
3. **Cyber-Résilience** : Capacité à détecter, répondre et récupérer rapidement

6.1 Zoning et Segmentation (IEC 62443)

L'architecture s'articule autour de quatre zones principales :

Zone 1 : OT Terrain (Capteurs & SCADA)

- Composition : capteurs IoT, RTU, automates SCADA locaux, réseaux LoRa/ModbusTCP

- VLAN : 10.100.0.0/24 (capteurs), 10.120.0.0/24 (SCADA)
- Flux autorisés : capteurs → Edge SEULEMENT (LoRa, MQTT signé)
- Criticité : **Très élevée**
- Mesures : chiffrement TLS/DTLS, cycle de vie IoT (M1), segmentation (M2)

Zone 2 : Edge (Passerelles)

- Composition : Edge Gateways assurant filtrage, validation, chiffrement
- VLAN : 10.110.0.0/24
- Flux autorisés : OT (entrant LoRa/ModbusTCP) + Cloud (sortant MQTT/HTTPS signé)
- Criticité : **Critique**
- Mesures : MFA SSH (M3), EDR (M5), durcissement OS (CSC 4), cycle de vie (M1)

Zone 3 : IT Bureautique

- Composition : postes travail, serveurs métier, annuaire Active Directory
- VLAN : 10.300.0.0/24
- Flux autorisés : accès internet (HTTPS, DNS, SMTP), accès Cloud via bastion
- Criticité : **Élevée**
- Mesures : RBAC AD (CSC 6), MFA, DLP (M4), sensibilisation (M7)

Zone 4 : Cloud (Supervision Centralisée)

- Composition : portail web, API, data lake, modules analytique
- Accès : internet chiffré via VPN/HTTPS
- Criticité : **Critique**
- Mesures : CSPM (M4), authentification forte API (M3), chiffrement au repos (CSC 3), backups immuables (M5)

Zone DMZ (Interconnexion IT-OT)

- Composition : pare-feu de conduit, jump-server (bastion durci), proxy applicatif, collecteur logs
- Flux par défaut : **Deny All**, Accept Only Necessary (whitelist stricte)
- Exemple règles :
  - ALLOW IT.admin → SCADA.ssh:22 via bastion + MFA
  - ALLOW IT.apps → Cloud.api:443 (HTTPS)
  - DENY IT.user → OT (capteurs, SCADA)
  - ALLOW OT → IT SEULEMENT syslog:514 pour journalisation
- Mesures : PAM (M3), détection anomalies EDR, logs immuables (M6)

6.2 Authentification et Gestion des Accès

Principes :

- MFA obligatoire pour TOUS les accès administrateur (Edge, SCADA, Cloud)
- PAM (Privileged Access Management) : gestion centralisée des comptes privilégiés
- Isolation comptes OT ≠ IT (jamais partager Active Directory entre zones)
- Rotation mots de passe : 90 jours pour comptes humains, 30 jours pour comptes de service
- Audit de toutes les élévations de privilèges

Implémentation :

- **Comptes OT** : Stockés dans annuaire dédié (LDAP sécurisé) distinct d'AD IT
- **Accès SCADA** : SSH avec clés privées + MFA token (OTP ou authenticateur mobile)
- **Accès Cloud** : MFA TOTP ou U2F ; certificats clients pour API
- **Bastion d'administration** : Enregistrement vidéo des sessions ; alertes actions sensibles
- **Gestion des secrets** : Vault HashiCorp ou CyberArk pour clés API et certificats

Références EBIOS : M3 (MFA/PAM) ; couvre SR3, SR6.

6.3 Chiffrement et Gestion des Certificats

Standards Appliqués :

- TLS 1.2 minimum (TLS 1.3 recommandé) pour tous les flux réseau IT/Cloud
- DTLS pour communications sans fil (capteurs LoRa)
- Certificats X.509 pour authentification mutuelle (client/serveur)
- PKI dédiée pour IoT et OT (distinct de PKI IT)

Gestion du Cycle de Vie :

- Flux Capteur↔Edge↔Cloud : Certificats signés par CA IoT interne (durée 2 ans capteurs, 1 an Edge)
- Révocation via OCSP ou CRL (Certificate Revocation List)
- Flux Edge↔Cloud : VPN IPSec ou TLS tunnel avec certificats signés par CA Cloud
- Renouvellement automatisé avant expiration (alerte 60j avant)

Références EBIOS : M1 (cycle de vie incluant certificats), M7 (chiffrement) ; couvre SR1, SR2.

6.4 Supervision Centralisée et Détection d'Anomalies (SOC OT/IT)

Architecture SOC :

- SIEM centralisé (Splunk, ELK) agrégeant logs de toutes les zones
- Agents de sécurité (EDR, Syslog forwarders) sur Edge Gateways, SCADA, serveurs IT
- Corrélation d'événements : identification patterns dangereux (kill chain)

Indicateurs Surveillés :

- **Capteurs/Edge** : hausse erreurs transmission, certificats expirant, firmware obsolète, tentatives d'accès échouées
- **SCADA** : commandes non autorisées, écritures sur variables critiques, arrêts pompes inattendus
- **Flux réseau** : trafic vers IPs non autorisées, protocoles suspects, scans ports
- **Cloud** : accès heures inhabituelles, téléchargements massifs, modification ACL buckets
- **Bastion** : tentatives ssh multiples, exécutions cmd inhabituelles, logs réseau

Règles d'Alerte Critiques :

- Certificat capteur expiré ou révoqué → alerte immédiate, intervention manuelle requise
- Tentative SSH bastion en dehors heures travail + accès OT → suspicion latéralisation
- Modification configuration Edge sans ticket d'autorisation → escalade RSSI
- Trafic anormal vers adresses non whitelistes → isole la connexion, alerte SOC
- Connexion simultanée à partir de 2 localisations géographiques → compte compromis suspecte

Références EBIOS : M6 (SOC OT/IT) ; détecte tous scénarios SR1–SR7.

6.5 Résilience et Plan de Reprise d'Activité

Sauvegardes :

- Backups immuables Cloud (WORM – Write Once Read Many)
- Stockage multi-région (EU + secours secondaire hors-EU si nécessaire)
- Test PRA trimestriel avec basculement complet
- RTO cible : 4h ; RPO cible : 1h

Redondance :

- Edge Gateways : 2 unités en redondance active-passif (failover automatisé en 30 sec)
- Cloud : multi-région avec basculement automatisé
- Contrat SLA : Cloud fournisseur garantit disponibilité 99.95%

Références EBIOS : M5 (backups), M8 (redondance) ; couvre SR5 (panne Cloud).

6.6 Matrice de Correspondance : Scénarios → Mesures → Composants d'Architecture

Scénario	Risque	Mesures EBIOS	Composants Archi
SR1 – Compromission IoT	Malware firmware, fausses données	M1, M2, M7	Cycle de vie IoT, segmentation, TLS/DTLS, EDR Edge
SR2 – Fuite données	Exposition Cloud misconfiguration	M4, M3	CSPM, DLP, chiffrement au repos, audit ACL
SR3 – Ransomware Edge	Indisponibilité chaîne OT	M3, M5, M6	MFA, EDR, sauvegardes immuables, SOC alerte
SR4 – Injection données	Intégrité compromised	M1, M8	Journalisation immuable, validation HMAC
SR5 – Panne Cloud	Perte pilotage global	M5, M8	Multi-région, Edge backup, test PRA
SR6 – Contamination IT-OT	Latéralisation vers SCADA	M2, M6	DMZ, bastion, pare-feu, SOC corrélation
SR7 – Erreur firmware maj	Dysfonctionnement actifs	M1, M7	Supervision patching, validation pré-déploiement

Table 5: Traçabilité Scénarios de Risque → Mesures → Architecture

7. PLAN DE TRAITEMENT DU RISQUE

Le plan de traitement du risque détaillé (EBIOS RM Atelier 5) décompose les mesures par domaine, responsable, délai et priorité :

Mesure	Domaine/Objectif	Responsable	Délai Cible	Priorité
M1	Cycle de vie IoT : firmware signé, patchs, certificats, inventaire	Équipe IoT	3 mois	**Haute**
M2	Segmentation réseau IT-OT selon IEC 62443 (zones, DMZ, pare-feu)	RSSI OT + Infra	4 mois	**Haute**
M3	MFA et PAM sur tous accès administrateur Edge et SCADA	DSI SecOps	3 mois	**Haute**
M4	CSPM (Cloud Security Posture Management) et DLP	Cloud SecOps	2 mois	Moyenne
M5	Sauvegardes immuables Cloud et tests PRA trimestriels	Infra OT/Cloud	2 mois	Moyenne
M6	SOC OT/IT intégré, SIEM Splunk/ELK, corrélation événements	SecOps	6 mois	**Haute**

M7	Sensibilisation et formation Sécurité IoT/OT pour personnel	RSSI + RH	3 mois	Moyenne
M8	Redondance multi-région Cloud et Edge Gateways backup	DSI Infra	5 mois	Moyenne
M9	Audits externes et Red Team IoT annuels	RSSI + Tiers	9 mois	Moyenne

Table 6: Plan de Traitement du Risque Détaillé

7.1 Feuille de Route d'Implémentation

Phase 0 (Mois 1–2) : Fondations Sécurité

Responsables : DSI, CloudSecOps, Infra OT

- M3 : Déploiement MFA et PAM sur Edge Gateways (priorité immédiate)
- M4 : Activation CSPM et DLP sur Cloud (audit misconfiguration)
- M5 : Mise en place sauvegardes immuables et premiers tests PRA

Phase 1 (Mois 3–4) : Inventaire et Segmentation

Responsables : Équipe IoT, RSSI OT, Infra réseau

- M1 : Déploiement scanners inventaire (Nessus, CMDB) ; établissement cycle de vie firmware
- M2 : Mise en oeuvre segmentation zones VLAN et pare-feu d'interconnexion IT-OT

Phase 2 (Mois 5–6) : Détection et Sensibilisation

Responsables : SecOps, RSSI, RH

- M6 : Activation SOC OT/IT et intégration SIEM
- M7 : Lancement campagne sensibilisation et formations security

Phase 3 (Mois 7–18) : Résilience et Audits

Responsables : DSI, RSSI

- M8 : Déploiement redondance multi-région Cloud et failover automatisée
- M9 : Organisation audit externe sécurité et premier Red Team

7.2 Indicateurs de Succès (KPI)

- % capteurs avec firmware à jour (cible : 95% en M+6)
- % comptes administrateur avec MFA actif (cible : 100% en M+3)
- Temps moyen alerte SOC → escalade RSSI (cible : < 15 min)

- Couverture patching vulnérabilités CVSS 7+ (cible : patchs en 30 jours)
- Disponibilité du service d'eau (cible : 99.95%)
- Nombre incidents SR1–SR7 détectés avant dommage (cible : 100%)
- Taux cliquage phishing simulé (cible : < 5% après 6 mois formation)
- Temps réponse incident critiques (cible : 1h)

8. CONCLUSION

Le projet **Montfranc Smart City – Smart Water Management** confronté à une surface d'attaque tendue du fait de la convergence des technologies IT et OT. L'application rigoureuse et coordonnée de trois méthodologies complémentaires – **EBIOS RM** (analyse de risques), **CIS CSC v8.1** (contrôles prioritaires), et **NIST CSF 2.0** (gouvernance) – combinée avec une **architecture cible de défense en profondeur** et de cyber-résilience, permet d'atteindre un **niveau de risque résiduel modéré et maîtrisé**.

Synthèse des Risques Résiduels

Scénario	Risque Brut	Risque Résiduel	État Maîtrise
SR1 – IoT	Critique	Modéré	M1, M2, M7
SR2 – Fuite données	Critique	Modéré	M4, M3
SR3 – Edge ransomware	Critique	Modéré	M3, M5, M6
SR4 – Injection données	Élevée	Faible	M1, M8
SR5 – Panne Cloud	Élevée	Faible	M5, M8
SR6 – Contamination IT-OT	Critique	Modéré	M2, M6
SR7 – Erreur maj	Moyenne	Faible	M1

Table 7: Tableau Récapitulatif : Risques Bruts vs Résiduels

Points Clés de Succès

- **Gouvernance claire** : COPIL sécurité avec pilotage mensuel des mesures M1–M9
- **Priorités alignées** : M1–M3 (fondations) puis M6–M8 (détection et résilience)
- **Coordination multi-acteurs** : SLA de sécurité contractuels avec tous les prestataires
- **Supervision continue** : SOC OT/IT 24/7 avec escalade ANSSI pour incidents critiques
- **Exercices réguliers** : Red Team annuels et tests PRA trimestriels
- **Conformité réglementaire** : NIS2, RGPD, ANSSI IoT, IEC 62443 intégrées dès l'architecture

Perspectives de Consolidation

- **Long terme (année 2)** : Extension des contrôles CIS CSC aux 8 contrôles complémentaires (CSC 5, 8, 9, 13, 14, 15, 16, 18)

- **Évolution Zero Trust** : Renforcement du Zero Trust étendu aux capteurs IoT (micro-segmentation, attestation firmware)
- **Audits tiers** : Audit ISO 27001, certification Cyberscore ANSSI

L'impact attendu : réduction de **60–70%** du risque cyber sur 18 mois, tout en préservant la continuité et la performance critique du service public d'eau de Montfranc.

9. RÉFÉRENCES

1 ANSSI. (2023). *Bonnes pratiques pour la sécurité des objets connectés – ANSSI IoT*. https://www.ssi.gouv.fr

2 NIST. (2024). *Cybersecurity Framework CSF Version 2.0*. https://www.nist.gov/cyberframework

3 NIST. (2023). *Guide to Operational Technology OT Security – SP 800-82 Rev. 3*. https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-82r3.pdf

4 IEC. (2013). *Industrial Automation and Control Systems Security – IEC 62443 Series*. International Electrotechnical Commission.

5 SANS Institute / CIS. (2023). *Critical Security Controls v8.1*. https://www.cisecurity.org/controls/v8-1

6 CNIL/ANSSI. (2023). *Conformité RGPD et sécurité des données en France*. https://www.cnil.fr

7 European Commission. (2022). *Directive NIS2 – Network and Information Security*. Official Journal of the European Union.

8 ISO/IEC. (2022). *Information Security Management Systems – ISO/IEC 27001:2022*. International Organization for Standardization.

9 Projet MONTFRANC SMART CITY. (2025–2026). Analyse EBIOS-RM Ateliers 1–5 ; Plateforme CIS CSC v8.1 Gestion intelligente de l'eau ; Architecture NIST SP 800-82r3.